| Mindsmiths | Malware Outbreak Management | | | |
|---|---|---|---|---|
| | **ID** | MOM | **Author** | Hrvoje Kovačević |
| | **Version** | 1.1 | **Date** | 01.03.2021. |

## Content


**History of Changes in documented information** 1

**Overview** 2

**Purpose** 2

**Process** 2

1. Detection and Identification 2
    - Determine fully if a malware outbreak has occurred. 2
    - Obtain information about the malware 3
    - Perform preliminary assessments 3
    - Record all actions taken 3
2. Escalation 4
3. Containment 4
    - Identify infected systems 4
    - Contain the outbreak 4
    - Keep records of all actions taken 5
4. Eradication 5
5. Recovery 6
6. Aftermath 6


## History of Changes in documented information

| Date | Created by | ID | Version | Change |
|---|---|---|---|---|
| 26.04.2020. | Hrvoje Kovačević | MOM | 1.0 | Initial document created |
| 01.03.2021 | Hrvoje Kovačević | MDM | 1.1 | Update |
| | | | | |
| | | | | |
| | | | | |
| | | | | |

| Mindsmiths | Malware Outbreak Management | | | |
|---|---|---|---|---|
| | **ID** | MOM | **Author** | Hrvoje Kovačević |
| | **Version** | 1.1 | **Date** | 01.03.2021. |

| | | | | |
|---|---|---|---|---|
| | | | | |
| | | | | |

## Overview

Given that attackers are now moving away from attacks that are merely a nuisance or destructive towards an activity that is motivated by financial gain, malware attacks have become more sophisticated and a significant concern to organizations. A large-scale malware attack often referred to as a malware outbreak, can cause widespread damage and disruption to an organization, and necessitate extensive recovery time and effort. It is, therefore, crucial to implement adequate preventive measures, such as deploying protection and detection tools, to safeguard an organization from malware attacks.

However, there is no such thing as bulletproof protection in the world of information security. It is also important that the organization develop a robust information security incident procedure so that personnel is better prepared to handle malware outbreaks in a more organized, efficient, and effective manner.

## Purpose

As defined in the Security Incident Handling for Company section, an incident response process should have three main stages: "Planning and Preparation", "Response" and "Aftermath". This section outlines the steps in the stages "Response" and "Aftermath" which are important to the complete handling of a malware outbreak.

## Process

## 1. Detection and Identification

**Determine fully if a malware outbreak has occurred.**

The objective of this step is to determine whether a malware outbreak has occurred. Typical indications of a malware outbreak include any or all the following:

1. Users complain of slow access to the Internet, exhaustion of system resources, slow disk access, or slow system boots.
2. A number of alerts have been generated by a Host-based Intrusion Detection System (HIDS), or by anti-malware software.
3. There is significantly increased network usage.
4. A number of access violation entries have been noticed in perimeter router logs or firewall logs.
5. A surge of out-bounced SMTP traffic originating from internal IP addresses has

been detected.
6. A large number of port scans and failed connection attempts have been detected.
7. The system administrator notices an unusual deviation from typical network traffic flows.
8. Security controls such as anti-malware software and personal firewalls have been disabled on many hosts.
9. General system instability and crashes.

**Obtain information about the malware**

Upon discovery of any of the above symptoms, IT staff should immediately check and validate all suspicious activity to determine if an outbreak has occurred. Once it is confirmed that this is a malware security breach, it is important to collect information about the malware, as this will be essential for the containment and eradication process.

Information about the malware can be obtained from anti-malware software vendors' websites if the malware has been around for some time, by reviewing alerts from anti-malware software, by examining firewall and router log files. The following questions can help identify the characteristics of the malware:

1. What kind of malware is it (Network worm, mass-mailing worm, virus, or trojan horse, etc.)?
2. How does the malware propagate (By attacking vulnerable network service? By mass mailing?)?
3. If the malware propagates by attacking vulnerable service, what is the vulnerability being exploited? Has a patch for addressing the vulnerability been released? What are the services or ports that are being attacked?
4. Does the malware plant backdoors on the infected system?
5. How can the malware be removed from the affected system? Are there any removal tools available?

**Perform preliminary assessments**

Once an outbreak is identified, IT staff should assess the scope, damage, and impact of the outbreak in order to effectively deal with it.

**Record all actions taken**

IT staff should record all actions taken to deal with the outbreak and any corresponding results. This can facilitate incident identification and assessment, and provide evidence for prosecution or other useful information for subsequent incident handling stages. Logging should be carried out throughout the whole security incident response process.

## 2. Escalation

The second step in incident response is to notify all appropriate parties and escalate the incident to the appropriate level following a predefined escalation procedure. The information provided during the escalation process should be clear, concise, accurate, and factual. Providing inaccurate, misleading, or incomplete information may hinder the response process or may even worsen the situation. It is crucial to bear in mind that information about incidents should be disclosed only on a need-to-know basis.

## 3. Containment

The third step of response to a malware incident is containment. The following are activities that should be carried out in the containment stage:

### Identify infected systems

Clearly identifying the infected systems is always the first step in containment. Unfortunately, it is also a very complicated process due to the dynamic nature of today's IT environment. The following are some suggestions that may help identify infected systems in a managed environment:

1. Perform thorough malware scanning on all the systems with the latest malware definitions as well as with updated anti-malware detection and repair engines. As no single anti-malware software can uncover all types of malware, it may be necessary to use more than one anti-malware scanning tool to ensure that all malwares are detected.
2. Review all log files of routers and firewalls.
3. Provide users with instructions on how to identify infections.
4. Configure IPS or IDS to identify activities associated with infections.
5. Perform packet sniffing routines to look for the network traffic matching the characteristics of the malware.

### Contain the outbreak

Containing the outbreak can be done in various ways; the following are common tactics:

1. By using automated tools.

   Containing the spread of the malware can be done with automated tools, such as anti-malware software, IDS, and IPS. If the malware is not detected by existing anti-malware protection systems, even with the latest definition applied, support from anti-malware software vendors should be sought to create a new definition that covers the malware.

2. By disabling connectivity.

A malware outbreak can be effectively contained by quickly disconnecting infected systems from the overall network infrastructure, which can be accomplished by applying access controls on network devices or physically disconnecting network cables. In some cases, in order to contain the spread of malware to other sections of the organization, it may be necessary to temporarily disconnect the network segments concerned from the network backbone. However, this containment strategy will certainly affect the operation of other non-infected systems in the segment.

3. By disabling services.

   Malware may propagate through network services, for example, network shared drives. Temporarily blocking or even shutting down the network services used by malwares helps to contain incidents.

4. By eliminating vulnerability.

   Malware may spread by attacking vulnerable network services. By addressing the vulnerabilities that have been exploited by the malware, such as applying security patches on vulnerable systems, the propagation channels can be eliminated, hence containing the spread. In addition, some misconfiguration, such as loose access controls on network-shared drives, can also be leveraged by malware. By rectifying any misconfigurations, the spread of malware can be contained.

5. By user participation.

   User participation is significant to the containment process in an environment where only a limited number of technical support staff are available to handle an outbreak, for example in small remote branch offices or in a non-managed office environment. Users should be provided with clear instructions on how to identify infections and what measures should be taken if a system is confirmed infected, such as running the anti-malware removal tools on the infected system.

**Keep records of all actions taken**

It is important to keep a solid record of all actions taken at this stage, because some containment measures may require temporary modifications to the configuration or settings of network infrastructure and systems. These modifications will need to be removed after the incident.

## 4. Eradication

Eradicating a malware outbreak should be designed to remove the malware from all infected systems and media, and rectify the cause of the infection. Prior to carrying out the eradication process, it is advisable to collect all necessary information, including all log files, which may have to be deleted or reset during the cleanup process, which will

be useful in subsequent investigations.

Anti-malware scanning software and removal tools are commonly used as the primary means of eradication. However, in some cases, it may be necessary to rebuild infected systems from scratch. For instance, if the malware has downloaded and planted a backdoor on infected systems, rebuilding all systems may be the most reliable action to be taken in order to restore the integrity of the systems. Rebuilding a system generally includes the following actions:

1. Reinstalling the system from a trusted source, such as system installation disk or trusted clean system image.
2. Securing newly installed systems, such as checking and ensuring that the latest definitions as well as the updated anti-malware detection and repair engines, and necessary security patches have been applied on each machine.
3. Restoring data from known, clean backup media.

## 5. Recovery

Clearly, the main purpose of the recovery step is to restore all systems to normal operation. In a malware outbreak, recovering the functionality and data of infected systems may have already been carried as part of the eradication process. Apart from restoring the infected systems, removing any temporary containment measures, such as suspended network connections, is another main aspect of the recovery process.

Prior to the removal of the containment measures, one important step is a pre-production security risk assessment to ensure that no infection is detected and that the cause of the original infection is rectified.

All related parties should be notified before the resumption of suspended services. IT personnel should restore specific functions and servers stage by stage, in a controlled manner, and in the order of demand, e.g. the most essential services or those serving the majority should resume first. After resuming the suspended services, it is important to verify that the restoration operation has been successful and that all services are back to normal operation. Additional monitoring measures may be implemented to watch for any suspicious activity in the network segments concerned.

## 6. Aftermath

Restoring infected systems to normal operation does not mark the end of a malware outbreak. It is also important to perform necessary follow-up action. This may include a full evaluation of the damage caused, system refinements to prevent recurrence of the incident, updates to security policies and procedures, and investigation of the case for subsequent prosecution. Activities in this stage can include the following:

1. Review the effectiveness of existing malware protection procedures and

mechanisms, including central control and management on malware definitions distribution and detection and repair engine update, scheduled regular malware scanning, etc.

2. Update relevant policies, guidelines, and procedures whenever necessary.
3. Enforce the new security measures introduced in the reviewed policy/guidelines/procedures to protect systems against future attacks.
4. Remind users to follow security best practices, such as not opening an email from unknown/suspicious email sources, updating security patches and malware definitions on a regular basis and whenever necessary, etc.